

Université

Toulouse Paul Sabatier

Audit de maturité SSI et audit technique de MEDICA-SERVICES

Rapport d'audit

TD 2 · Maturité SSI · méthode SGDN/DCSSI 2007

Réalisé par :
Team
Marc
Matteo
Bernard
M2 SSIR

Année universitaire 2026-2027

Table des matières

Synthèse pour la direction **2**

1 Introduction **2**

2 L'entreprise et le périmètre audité (G1) **2**
2.1 Organisation de MEDICA-SERVICES 2
2.2 Périmètre retenu 3
2.3 Limites et informations manquantes 4

3 Niveau adéquat de maturité (G2) **4**

4 Maturité effective des sept processus (G3) **5**

5 Audit technique sur pièces (T1 à T4) **6**
5.1 Architecture, flux et segmentation (T1) 6
5.2 Identités, privilèges et MFA (T2) 7
5.3 Vulnérabilités et correctifs (T3) 7
5.4 Détection, journaux et sauvegardes (T4) 8

6 Corrélation gouvernance et technique (T5) **9**

7 Risques, arbitrage et feuille de route (G4) **9**
7.1 Scénarios de risque 9
7.2 Arbitrage sous plafond de 120 000 € 10
7.3 Feuille de route SSI sur douze mois 11

8 Organisation du travail de l'équipe **12**

9 Conclusion **13**
9.1 Bilan 13
9.2 Décisions demandées 13
9.3 Limites et perspectives 13

Annexes **14**

A Autodiagnostic détaillé (onglet 01) **14**

B Maturité effective détaillée (onglet 02) **15**

C Registre des constats techniques (onglet 03) **17**

D Registre des risques (onglet 04) **20**

E Plan d'action détaillé (onglet 05) **21**

F Planning et état des tâches **23**

G Sources **24**

Synthèse pour la direction

MEDICA-SERVICES héberge et exploite les applications de gestion de douze établissements de soins privés (P01). Ses environnements portent des identifiants de patients et des données de santé (P05). Ces enjeux fixent son **niveau adéquat de maturité à 4**, c'est-à-dire le niveau de rigueur qu'elle devrait viser.

Les pièces démontrent un **niveau 1** pour la stratégie, les risques, la supervision et la réalisation des mesures, et un **niveau 2** pour les règles, la conception et l'exploitation. Aucun processus n'atteint le niveau 3, d'où un écart de deux à trois niveaux. L'affirmation de la DSI selon laquelle tous les comptes privilégiés ont un MFA est contredite, puisque seuls six sur dix sont enrôlés (T04). Celle de la DG sur les tests trimestriels de restauration n'est pas démontrée, deux services sur neuf ayant un procès-verbal (T09).

Trois risques dominent. Le premier est la prise de contrôle d'un compte à privilèges, illustrée par la connexion d'admin-old le 9 octobre suivie d'un ajout à un groupe d'administrateurs, puis par la fermeture automatique de l'alerte AL-1048 sans examen tracé (T07, T08). Ces signaux appellent une investigation sans prouver une intrusion. Le deuxième est l'impossibilité de reprendre le service en 8 heures après un rançongiciel, car les postes peuvent joindre les sauvegardes (FW-31). Le troisième concerne APP01, à qui manque un correctif critique (T05, T06).

Nous demandons trois décisions à la direction. Il s'agit d'abord de lancer dès maintenant l'investigation d'AL-1048 et les mesures conservatoires. Il s'agit ensuite d'engager 116 000 € sur 120 000 € pour six actions. Il s'agit enfin d'accepter par écrit, pour douze mois, les risques résiduels des mesures différées.

1 Introduction

La direction générale de MEDICA-SERVICES nous a mandatés pour évaluer la maîtrise de sa sécurité des systèmes d'information. L'entreprise héberge des applications de soins pour des établissements privés, et une défaillance de son SI peut toucher la prise en charge de patients chez ses clients. La question posée est double. Quel niveau de rigueur l'entreprise devrait-elle viser, et quel niveau ses processus démontrent-ils réellement ?

Nous appliquons la méthode de maturité SSI publiée par le SGDN et la DCSSI en novembre 2007, utilisée ici comme référence pédagogique historique et non comme certification ou preuve de conformité actuelle. Ses douze questions donnent le niveau adéquat et ses sept processus donnent les niveaux effectifs. L'audit porte uniquement sur les pièces P01 à P17 et T01 à T10. Chaque conclusion cite sa pièce et distingue le fait, la déclaration, l'interprétation et l'information manquante. Aucun scan ni aucune connexion n'a été réalisé sur une infrastructure réelle.

Le rapport présente d'abord l'entreprise et le périmètre, puis le niveau adéquat et la maturité effective. Il expose ensuite l'audit technique et sa corrélation avec la gouvernance, avant de proposer les risques, l'arbitrage budgétaire et la feuille de route. L'organisation de notre travail et la conclusion le referment. Les tableaux détaillés figurent en annexe.

2 L'entreprise et le périmètre audité (G1)

2.1 Organisation de MEDICA-SERVICES

MEDICA-SERVICES emploie 220 personnes sur quatre implantations et dispose d'une DSI de 14 personnes (P01, P02). La figure 1 reprend son organisation. Seuls deux liens sont établis par les pièces. La DG approuve la stratégie SSI que la DSI applique, et le RSSI est rattaché à la DSI. Les autres rattachements ne sont pas précisés par P02 et ne sont donc pas tracés.

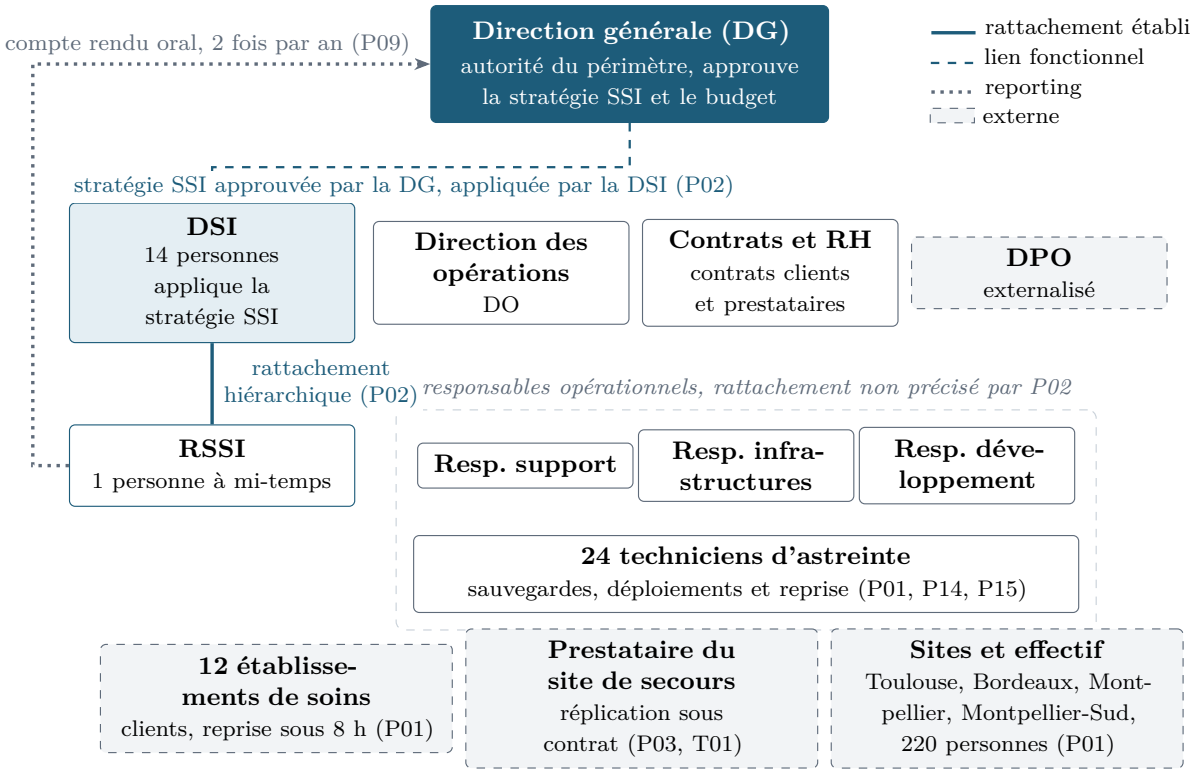


Figure 1. Organigramme de MEDICA-SERVICES d'après P01, P02 et P09.

Table 1. Qui gère quoi en matière de SSI

Acteur	Rôle établi par les pièces	Pièces	Rôle dans notre plan
Direction générale	Autorité du périmètre, approuve la stratégie SSI et l'enveloppe de 120 000 €	P02, P09, P16	Décide, accepte les risques résiduels
DSI	Applique la stratégie SSI. Infrastructure et comptes par hypothèse	P02	Pilote A08 et les règles FW
RSSI (mi-temps)	Recense quelques risques avec la DSI, rend compte oralement deux fois par an	P02, P09, P10	Pilote A01, A02, A03 et l'investigation
Resp. infrastructures	Cité par P02. Sauvegardes et correctifs par hypothèse	P02	Pilote A05 et A09
Support et astreinte	Connaît la procédure de restauration, 24 techniciens d'astreinte	P01, P15	Exécute les tests de restauration
Contrats et RH	Gestion des contrats et des ressources humaines	P02	Clauses prestataires, sensibilisation
DPO externalisé	Fonction externalisée	P02	Consulté sur les données de santé

2.2 Périmètre retenu

La méthode recommande un périmètre homogène en termes de responsabilité. Nous retenons le service d'hébergement et d'exploitation rendu aux clients, placé sous l'autorité de la DG.

Table 2. Périmètre retenu

Élément	Contenu retenu	Pièces
Bénéficiaires	12 établissements de soins, reprise sous 8 h des applications critiques	P01
Actifs essentiels	MEDI-PORTAL et sa base, identifiants patients et données de santé, ERP, ticketing	P03, P05, T01
Services supports	35 serveurs ou VM, Active Directory, Microsoft 365, VPN et bastion, sauvegardes, salle principale et salle de secours	P03, T01, T09
Interconnexions	Portail HTTPS public, liaisons contractuelles avec les clients, réplication vers le secours, SaaS	P03, P07, T01
Exclusions	SI des clients, fonctionnement interne des SaaS et du prestataire de secours, réseaux de Bordeaux, Montpellier et Montpellier-Sud non décrits, tout test actif	P01, T01, T04

2.3 Limites et informations manquantes

Les pièces sont des fragments. Une absence de justificatif est traitée comme une incertitude à lever et non comme la preuve qu'une action n'a pas eu lieu. Trois manques pèsent le plus sur nos conclusions.

Table 3. Informations manquantes et demandes de preuves

Information manquante	Conséquence	Demande de preuve
RTO et RPO par service, dépendances (T01, T09)	Engagement de 8 h invérifiable	Analyse d'impact, annexes contractuelles, entretien avec le responsable infrastructures
Liste exhaustive des comptes privilégiés et accès conditionnel (T04)	Taux MFA valable pour l'export seul	Export complet annuaire et SaaS, registre des exceptions
Suite donnée à AL-1048 et intégrité des journaux (T07, T08)	Événement du 9 octobre non qualifiable	Journaux bruts scellés, historique du ticketing, entretien avec le titulaire d'admin-old

3 Niveau adéquat de maturité (G2)

La méthode note douze questions de 0 à 3, garde le maximum de chaque famille de trois et convertit la somme des quatre maxima en niveau. La figure 2 présente les notes et le calcul. Les justifications complètes, pièce par pièce, figurent en annexe A.

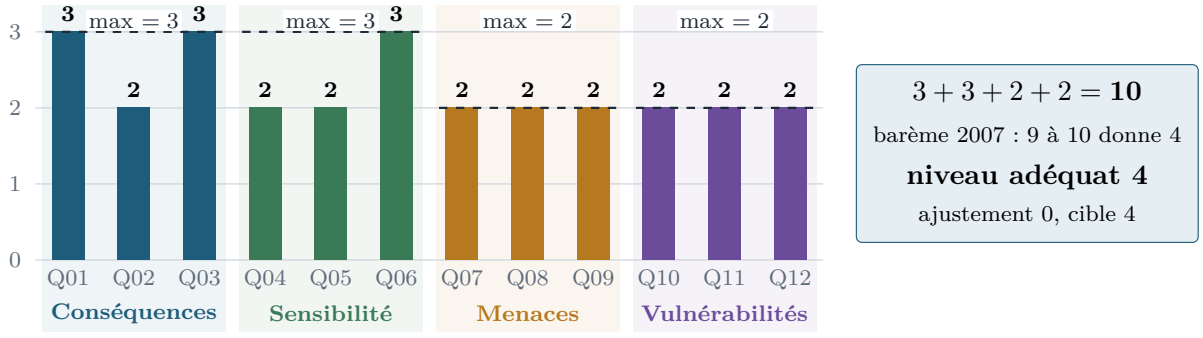


Figure 2. Notes Q01 à Q12, maxima par famille et niveau adéquat (onglet 01).

Table 4. Autodiagnostic DCSSI, synthèse

ID	Question	Note	Pièces	Confiance
Q01	Adhérence du SI aux missions	**3**	P01, P03, P04	Confirmé
Q02	Impacts internes	**2**	P01, P04	Probable
Q03	Impacts externes	**3**	P04, P05	Probable
Q04	Disponibilité	**2**	P01, P04, P05	Probable
Q05	Intégrité	**2**	P05	Probable
Q06	Confidentialité	**3**	P05, P07	Probable
Q07	Fréquence des sinistres	**2**	P06	Probable
Q08	Motivation des attaquants	**2**	P07	Probable
Q09	Moyens des attaquants	**2**	P07	Incertain
Q10	Hétérogénéité du SI	**2**	P08, T01	Confirmé
Q11	Ouverture du SI	**2**	P03, P07, T01, T02	Probable
Q12	Variabilité du SI	**2**	P06, P08	Confirmé

Le résultat est robuste. La cible resterait à 4 si la confidentialité était notée 2, la somme valant encore 9. Elle ne passerait à 5 que si l'ouverture du SI était jugée hors de contrôle à cause de l'accès public au portail. Nous ne retenons pas cette lecture, car la publication est unique, filtrée et protégée par un reverse proxy (`T01`, `T02`).

La méthode autorise un ajustement d'un niveau. Une baisse à 3 pourrait s'appuyer sur la taille de l'entreprise et sur un RSSI à mi-temps (`P02`). Nous ne la proposons pas, car les données touchent la santé de patients. La contrainte de moyens est mieux traitée par une progression par étapes. La décision revient à la DG.

4 Maturité effective des sept processus (G3)

L'échelle est cumulative. Un niveau n'est atteint que si toutes ses exigences et celles des niveaux inférieurs sont démontrées. Deux critères sont appliqués à tous les processus. Un compte rendu écrit des résultats vaut mesure qualitative, un compte rendu oral sans trace ne la vaut pas. La compétence est admise lorsqu'un rôle chargé de la sécurité est désigné. La figure 3 montre l'examen exigence par exigence.

		Stratégie	Risques	Règles	Supervision	Conception	Réalisation	Exploitation
N1	Pratiques de base	démontré	démontré	démontré	démontré	démontré	démontré	démontré
N2	Actions planifiées	démontré	non établi	démontré	non établi	démontré	indéterminé	démontré
N2	Acteurs compétents en SSI	démontré	démontré	démontré	démontré	déduit	démontré	démontré
N2	Pratiques en partie formalisées	démontré	non établi	démontré	non établi	démontré	démontré	démontré
N2	Mesures qualitatives	indéterminé	non établi	démontré	non établi	démontré	démontré	démontré
N2	Autorités informées	démontré	indéterminé	démontré	non établi	démontré	démontré	démontré
N3	Processus défini et standardisé	non établi	non établi	non établi	non établi	non établi	non établi	non établi
N3	Compétences appropriées	indéterminé	indéterminé	indéterminé	indéterminé	indéterminé	indéterminé	indéterminé
N3	Soutien de l'organisme	indéterminé	indéterminé	indéterminé	indéterminé	indéterminé	indéterminé	indéterminé
	Niveau démontré	**niveau 1**	**niveau 1**	**niveau 2**	**niveau 1**	**niveau 2**	**niveau 1**	**niveau 2**

Figure 3. Exigences cumulatives par processus et niveau démontré.

Table 5. Niveaux revendiqués, démontrés et indéterminés (onglet 02, cible 4)

Processus	Revendiqué	Démontré	Niveau supérieur	Preuves	Écart
Définir la stratégie SSI	Non déclaré	**1**	N2 indéterminé (mesures qualitatives et traces de compte rendu absentes)	P09, P02, P17	3
Gérer les risques SSI	Non déclaré	**1**	N2 non atteint (pas de planification ni de méthode)	P10, P06	3
Gérer les règles SSI	Non déclaré	**2**	N3 non atteint (pas de processus standardisé)	P11, P17, T06	2
Superviser la SSI	Non déclaré	**1**	N2 non atteint (contrôles non planifiés, pas de reporting)	P12, P06, T08	3
Concevoir les mesures SSI	Non déclaré	**2**	N3 non atteint (démarche non uniformisée)	P13, T02	2
Réaliser les mesures SSI	Non déclaré	**1**	N2 indéterminé (planification non démontrée)	P14, T02	3
Exploiter les mesures SSI	Non déclaré	**2**	N3 non atteint (pas de processus commun standardisé)	P15, P17, T03, T04, T06, T09	2

Aucune pièce n'affiche de niveau revendiqué. Quatre processus restent au niveau 1. La gestion des risques et la supervision manquent de planification et de formalisation (P10, P12). La stratégie et la réalisation ont un niveau 2 indéterminé, l'une faute de mesure qualitative documentée (P09), l'autre faute de planification démontrée, les déploiements étant seulement « souvent préparés » (P14). Les règles, la conception et l'exploitation atteignent le niveau 2. Aucun processus n'est standardisé sur tout l'organisme, ce qui exclut le niveau 3. Les réserves détaillées figurent en annexe B.

5 Audit technique sur pièces (T1 à T4)

5.1 Architecture, flux et segmentation (T1)

Le cloisonnement décrit par T01 est sain dans son principe. La surface exposée à Internet se déduit des règles FW-01 et FW-08, qui publient WEB01, et du point d'entrée VPN. Le scan fourni a été fait depuis la DMZ et non depuis Internet (T02). Un port ouvert n'y prouve aucune faille exploitée. Cinq règles appellent un contrôle.

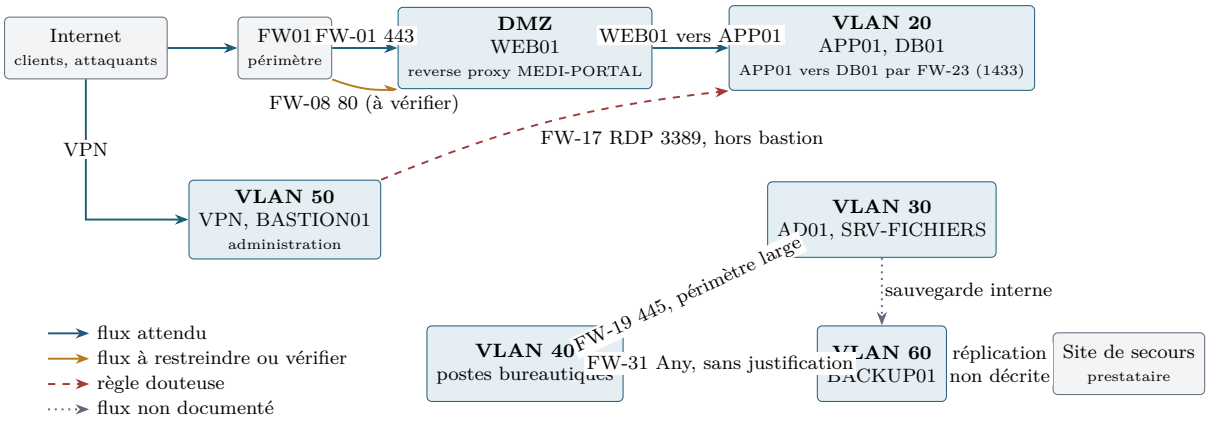


Figure 4. Zones de confiance et flux extraits de T01 et T02, sans journaux de trafic.

Table 6. Règles à contrôler

Règle	Constat	Lecture prudente	Contrôle complémentaire
FW-08	HTTP 80 ouvert sur WEB01	Redirection déclarée, non vérifiée	Requête de test, en-tête HSTS
FW-17	RDP du VPN vers tout le VLAN 20, « provisoire »	Contourne le bastion	Date d'expiration, passage par BASTION01
FW-19	SMB 445 de tous les postes vers le VLAN 30	Périmètre large	Liste des partages, restriction par groupe
FW-23	1433 de tout le VLAN 20 vers DB01	Source plus large qu'APP01	Emplacement de DB01, source limitée
FW-31	Any des postes vers les sauvegardes	Aucune justification	Journaux sur 30 jours, restriction, test

5.2 Identités, privilèges et MFA (T2)

L'export recense dix comptes privilégiés, dont six enrôlés MFA, soit $6/10 = 60\,\%$ (T03, T04). Ce taux concorde avec P03 et contredit la DSI (P17). Sans politique d'accès conditionnel, on ne sait pas si le second facteur est imposé. Si svc-backup est réellement non interactif, la couverture des comptes interactifs atteint $6/9 \approx 66{,}7\,\%$.

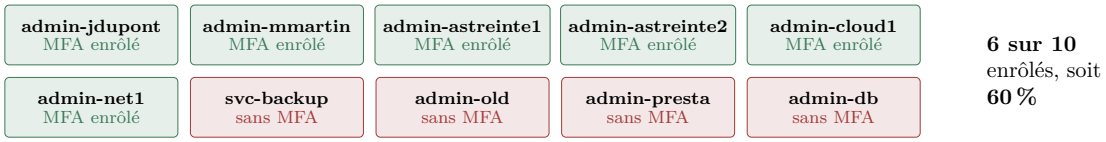


Figure 5. Comptes privilégiés de l'export et enrôlement MFA (T03, T04).

Quatre comptes appellent une action immédiate. Admin-old, administrateur de domaine dont la dernière activité documentée date de février 2025 alors qu'il apparaît dans les journaux du 9 octobre, doit être désactivé à titre conservatoire. Admin-presta et admin-db doivent être enrôlés ou couverts par une exception signée. Svc-backup doit être interdit de session interactive. La clôture se vérifie par un export exhaustif refait après correction.

5.3 Vulnérabilités et correctifs (T3)

Le score CVSS mesure une gravité technique, pas un risque métier. La priorité croise le score, l'exposition, la criticité et les mesures compensatoires. APP01 passe en tête bien qu'il ne soit pas exposé à Internet, car il est critique et joignable depuis la DMZ. WEB01, exposé, reste de priorité modérée.

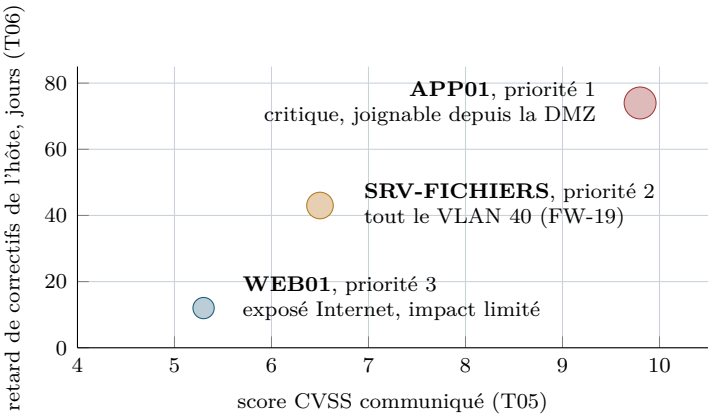


Figure 6. Score communiqué et retard de correctifs de l'hôte au 12 octobre 2026 (T05, T06).

Aucune exception n'est documentée et la PSSI ne fixe aucun délai par criticité (T06, P11). Les retards de T06 portent sur l'hôte et restent déclaratifs. Pour AD01, l'inventaire du 25 septembre doit être refait. Nous demandons les CVE, les versions et les historiques de déploiement.

5.4 Détection, journaux et sauvegardes (T4)

La figure 7 reprend les seuls faits de T07 et T08, en heure UTC.

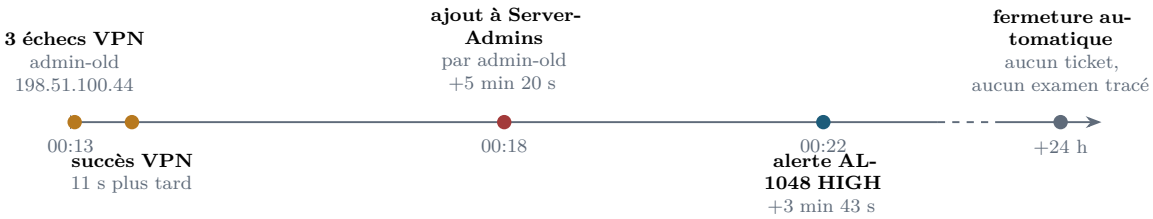


Figure 7. Chronologie neutre du 9 octobre 2026.

Ces signaux sont compatibles avec un usage illégitime du compte comme avec une intervention nocturne non documentée. La compromission n'est pas prouvée, faute de journaux scellés, de trace du second facteur et d'échange avec le titulaire. Nous recommandons la désactivation conservatoire d'admin-old, la revue de Server-Admins, la préservation des journaux, puis une investigation.



Figure 8. Services sauvegardés et dernier test de restauration documenté (T09).

Seuls deux services sur neuf ont un procès-verbal de test. Leur contenu n'est pas communiqué, si bien que le délai de 8 heures n'est pas démontré, et aucun RPO n'est fourni. L'absence de procès-verbal ne prouve pas l'absence de test. Nous proposons un procès-verbal annuel par service et un procès-verbal trimestriel pour MEDI-PORTAL, sa base, l'AD et l'ERP, avec une durée mesurée inférieure à 8 heures. Toute alerte HIGH devrait par ailleurs recevoir un ticket qualifié avant clôture.

6 Corrélation gouvernance et technique (T5)

Chaque constat technique est relié à un risque, au processus DCSSI concerné et à son niveau démontré, puis à une action et à son pilote. Le niveau provient de l'examen cumulatif de la section 4 et non du constat seul. La vérification attendue pour chaque ligne et les onze constats figurent en annexe C.

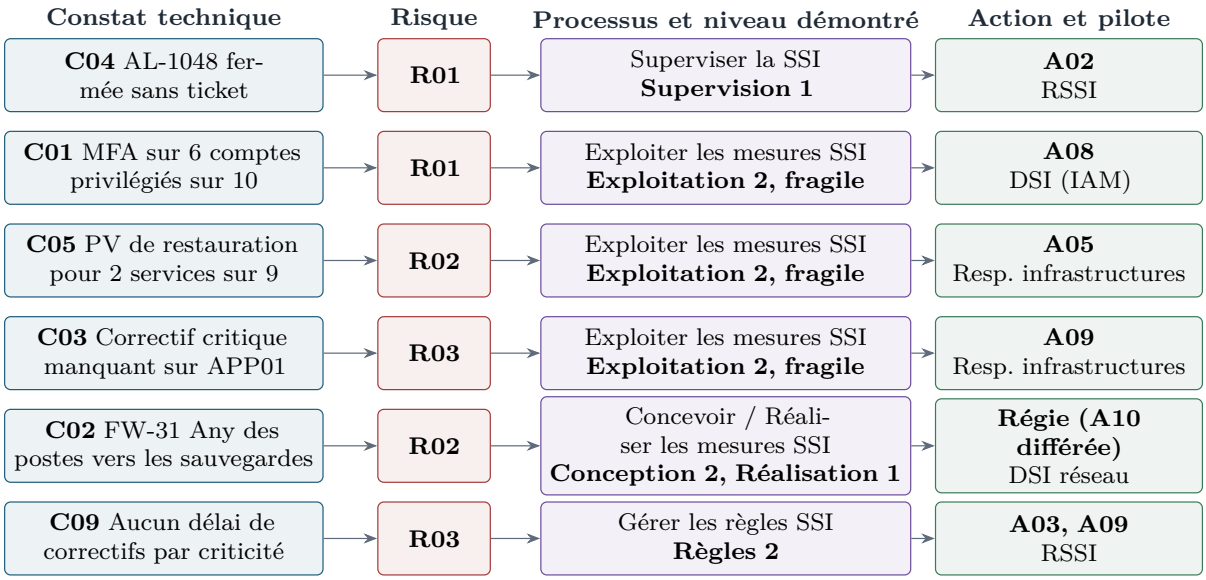


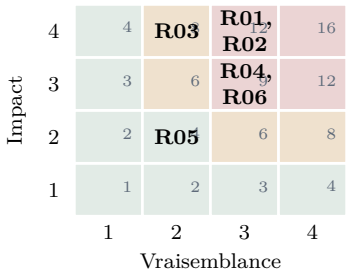
Figure 9. Du constat technique à l'action, six corrélations.

Les faiblesses techniques prolongent les lacunes de pilotage. L'alerte fermée sans examen tracé découle d'une supervision au niveau 1. Les retards de correctifs traduisent des règles sans délai. Les procès-verbaux manquants montrent une exploitation qui ne prouve pas l'efficacité de ses restaurations. Corriger les symptômes sans faire progresser les processus ne suffirait pas.

7 Risques, arbitrage et feuille de route (G4)

7.1 Scénarios de risque

Six scénarios traduisent les constats en enjeux métier. La cotation de 1 à 4 suit la notice et le score est le produit de l'impact par la vraisemblance. Le registre complet, avec menaces, faiblesses et mesures existantes, figure en annexe D.



ID	Scénario	I	V	I×V	Décision
R01	Prise de contrôle d'un compte à privilèges	4	3	**12**	Réduire (A08, A02)
R02	Reprise impossible dans le RTO de 8 h	4	3	**12**	Réduire (A05, A08, régie)
R03	Atteinte aux données via APP01 non corrigé	4	2	**8**	Réduire (A09)
R04	Divulgation depuis les partages de fichiers	3	3	**9**	Réduire en partie, résiduel accepté
R05	Dégradation des sessions du portail	2	2	**4**	Réduire (A09)
R06	Incident causé par un changement	3	3	**9**	Accepter 12 mois (A04 différée)

Figure 10. Matrice impact et vraisemblance, registre résumé (onglet 04).

R01 et R02 dominent avec un score de 12. R03 vaut 8, moins que R04 et R06, mais nous le plaçons parmi les risques majeurs pour son impact maximal sur les données de patients et parce qu'il se réduit vite. À score égal, R04 et R06 n'appellent pas le même traitement, le premier relevant de réglages techniques et le second d'une standardisation lourde.

7.2 Arbitrage sous plafond de 120 000 €

Les montants viennent de `P16` et `T10`. Le lot de restauration n'est compté qu'une fois, car il est commun aux deux pièces. L'outillage quantitatif (`A06`) et la détection outillée (`A11`) sont des alternatives, toutes deux différées, la mesure quantitative relevant du niveau 4.

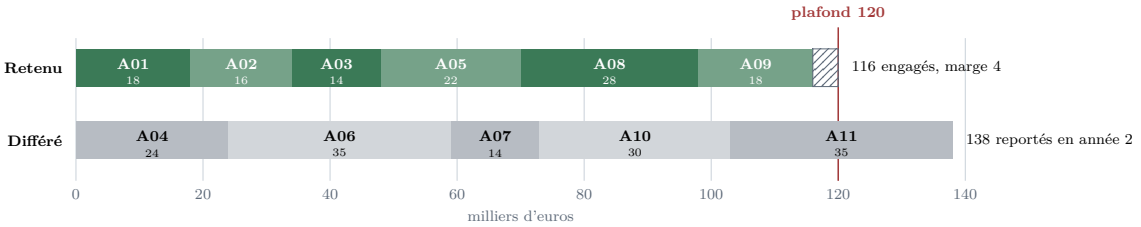


Figure 11. Actions retenues et différées, en milliers d'euros (onglet 05).

Table 7. Plan d'action, synthèse (détail en annexe E)

ID	Mesure	Coût	Choix	Pilote
A01	Registre et méthode des risques	18 000 €	**Retenu**	RSSI
A02	Supervision et reporting	16 000 €	**Retenu**	RSSI et exploitation
A03	PSSI et sensibilisation	14 000 €	**Retenu**	RSSI et RH
A04	Standardisation conception et réalisation	24 000 €	Différé	DSI
A05	Restauration et incidents	22 000 €	**Retenu**	Resp. infrastructures
A06	Outillage quantitatif	35 000 €	Différé	RSSI
A07	Conduite du changement	14 000 €	Différé	DG et RH
A08	MFA et privilèges	28 000 €	**Retenu**	DSI (IAM)
A09	Vulnérabilités et correctifs	18 000 €	**Retenu**	Resp. infrastructures
A10	Segmentation réseau	30 000 €	Différé	DSI réseau
A11	Détection et workflow SIEM	35 000 €	Différé	RSSI
	Engagement total	**116 000 €**		Marge 4 000 €

Le choix traite d'abord R01 et R02 et les processus les plus faibles, comme le recommande la méthode. Chaque report laisse un risque résiduel. Celui de A10 laisse R04 et une part de R02, celui de A04 laisse R06, celui de A11 limite la détection sur R01, celui de A06 prive le pilotage d'indicateurs chiffrés et celui de A07 expose à une faible adhésion. Ces risques doivent être acceptés par écrit par la DG. Les règles FW-31 et FW-17 sont restreintes en régie sans attendre, hypothèse à confirmer avec la DSI. La charge du RSSI à mi-temps reste une fragilité.

7.3 Feuille de route SSI sur douze mois

Cette feuille de route concerne MEDICA-SERVICES et non le calendrier de notre projet. Elle suppose une décision du CODIR à la mi-novembre 2026. Les mesures conservatoires sont engagées dès la remise du rapport.

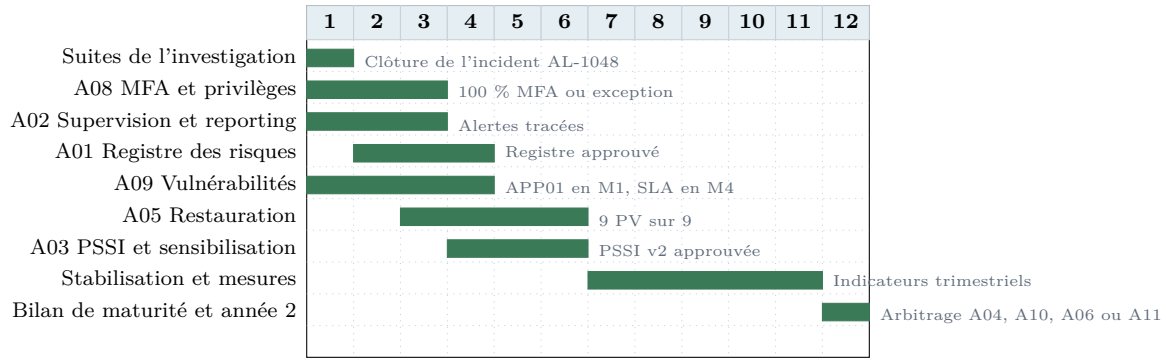


Figure 12. Feuille de route, mois 1 = décembre 2026.

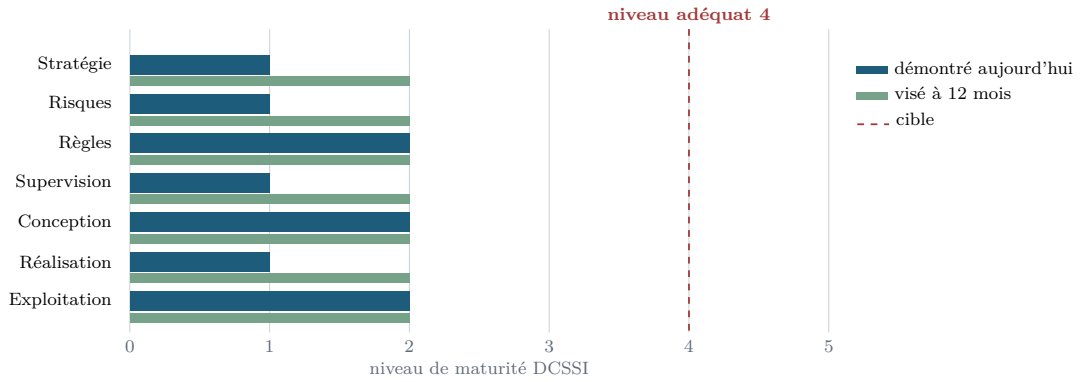


Figure 13. Trajectoire de maturité. Tous les processus au niveau 2 à douze mois, première étape vers la cible.

8 Organisation du travail de l'équipe

Le projet est planifié du 20 octobre au 10 novembre 2026 en quatre phases. Team coordonne et rédige, Marc porte la gouvernance, Matteo l'architecture, les identités et la présentation CODIR, et Bernard les vulnérabilités, les journaux et la grille Excel. Les barres sont des fenêtres de réalisation et non un travail à plein temps. Les dépendances sont de type fin-début, la liste complète figure en annexe F.

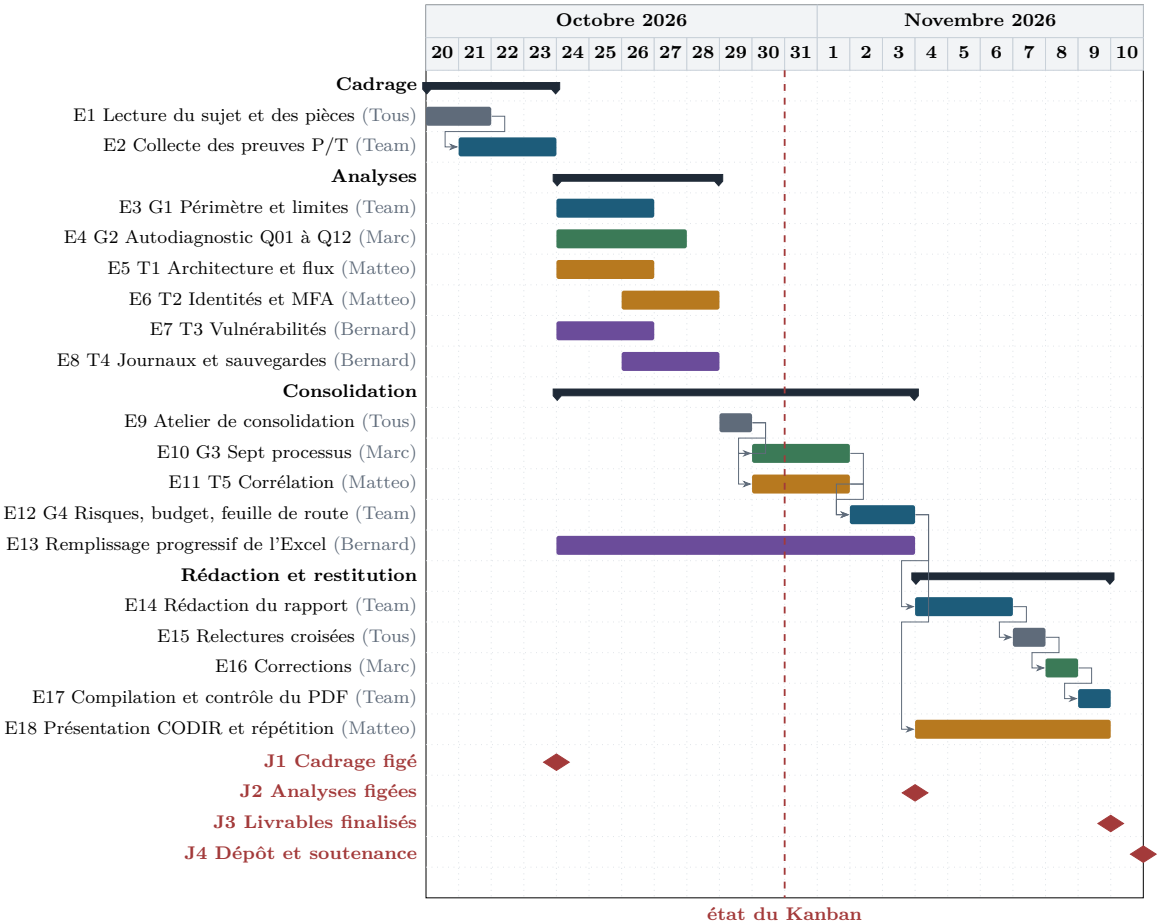


Figure 14. Diagramme de Gantt du projet. Couleur selon le responsable, jalons J1 à J4.

Le Gantt montre le planning cible, le Kanban l'avancement attesté. Au 30 octobre, la version

1 de chaque analyse et des livrables existe et attend la relecture croisée de l'équipe. L'atelier de consolidation et la lecture individuelle des pièces ne sont pas attestés. Aucune tâche n'est donc validée.

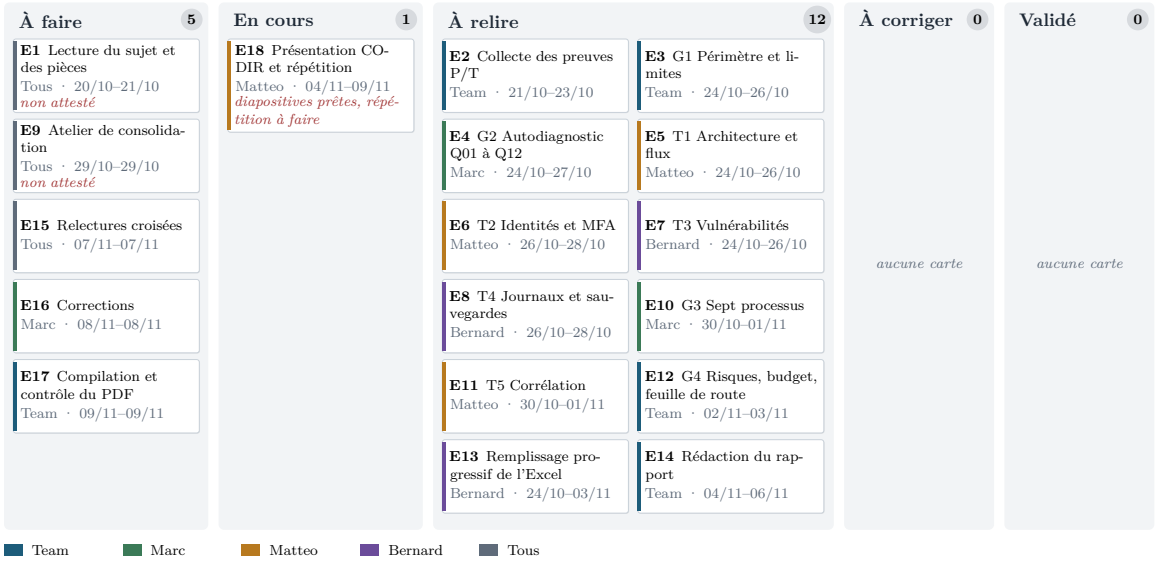


Figure 15. Kanban au 30 octobre 2026. Les identifiants E1 à E18 sont ceux du Gantt.

9 Conclusion

9.1 Bilan

MEDICA-SERVICES dispose de fondations réelles, avec une stratégie approuvée, une PSSI, des sauvegardes planifiées et des équipes compétentes. Ses pratiques restent dépendantes des personnes et ne produisent pas les preuves qui permettraient à la direction de vérifier ses propres affirmations. L'écart de deux à trois niveaux avec la cible 4 ne se comblera pas en une année. Le plan proposé ramène d'abord les sept processus au niveau 2 en traitant les risques les plus graves, dans le respect du plafond.

9.2 Décisions demandées

Nous demandons à la direction de lancer immédiatement l'investigation d'AL-1048 et les mesures conservatoires sur admin-old, FW-31 et FW-17. Nous lui demandons aussi d'engager 116 000 € pour les actions A01, A02, A03, A05, A08 et A09. Nous lui demandons enfin d'accepter par écrit, pour douze mois, les risques résiduels des mesures différées.

9.3 Limites et perspectives

Nos conclusions reposent sur des pièces partielles. Quatre preuves permettraient de les confirmer, le dossier d'investigation d'AL-1048, l'export exhaustif des comptes privilégiés, les procès-verbaux de restauration des sept autres services et les historiques de déploiement d'APP01. Elles pourraient débloquer le niveau 2 de la stratégie et de la réalisation sans modifier le niveau adéquat. Un bilan de maturité à douze mois mesurera la progression et préparera l'arbitrage de l'année 2.

Annexes

A Autodiagnostic détaillé (onglet 01)

Table 8. Notes, pièces et justifications

ID	Question	Note	Pièces	Justification factuelle	Confiance
Q01	Adhérence du SI aux missions	**3**	P01, P03, P04	MEDICA-SERVICES vend l'hébergement et l'exploitation d'applications pour 12 établissements de soins (P01). Sans SI il n'existe plus de prestation et les clients reviennent au papier (P04). Le SI est vital aux missions.	Confirmé
Q02	Impacts internes	**2**	P01, P04	La DG prévoit de fortes pertes contractuelles après une journée d'arrêt et le départ de certains clients si l'arrêt se prolonge (P04). Elle estime pouvoir poursuivre des prestations manuelles, ce qui écarte une conséquence fatale démontrée.	Probable
Q03	Impacts externes	**3**	P04, P05	Les établissements clients basculent sur papier (P04) et une altération non détectée peut provoquer des erreurs d'orientation et de prise en charge de patients (P05). La sécurité de personnes chez des tiers est en jeu. Note fondée sur des déclarations, sans étude d'impact chiffrée.	Probable
Q04	Disponibilité	**2**	P01, P04, P05	Une journée d'arrêt du portail est grave (pertes contractuelles, P04) et un arrêt prolongé affecte fortement la continuité des soins (P05). La DG décrit une activité dégradée et non un arrêt définitif, d'où 2 et non 3. Reprise contractuelle sous 8 h (P01).	Probable
Q05	Intégrité	**2**	P05	Les environnements contiennent des identifiants patients et des informations de santé. Une altération non détectée peut provoquer des erreurs d'orientation et de prise en charge (P05). L'impact est grave pour l'activité. Aucune pièce ne le décrit comme fatal pour l'entreprise, d'où 2 par cohérence avec Q02 et Q04.	Probable
Q06	Confidentialité	**3**	P05, P07	Identifiants patients et données de santé (P05). La DSI qualifie la divulgation de risque critique et les attaquants visés cherchent la revente de données et l'extorsion (P07).	Probable
Q07	Fréquence des sinistres	**2**	P06	Dix événements SSI enregistrés en 12 mois, soit environ 2,5 par trimestre (P06). Le registre n'étant ni exhaustif ni revu, la fréquence réelle peut être supérieure.	Probable

ID	Question	Note	Pièces	Justification factuelle	Confiance
Q08	Motivation des attaquants	**2**	P07	Menaces ciblées jugées plausibles et potentiellement fortement motivées par la revente de données et l'extorsion (P07). Aucune pièce ne justifie le niveau très important.	Probable
Q09	Moyens des attaquants	**2**	P07	P07 écarte les moyens illimités. Une cybercriminalité d'extorsion dispose plausiblement de moyens importants. Hypothèse d'auditeur sans effet sur le maximum du groupe, déjà fixé à 2 par Q07 et Q08.	Incertain
Q10	Hétérogénéité du SI	**2**	P08, T01	Windows, Linux, hyperviseurs, réseau multi-constructeurs, SaaS et application propriétaire héritée. P08 qualifie l'architecture de fortement hétérogène mais non extrêmement hétérogène.	Confirmé
Q11	Ouverture du SI	**2**	P03, P07, T01, T02	Interconnexions clients encadrées par contrat (P07). Le portail est ouvert à des internautes non maîtrisés, mais par une publication unique filtrée (FW-01, FW-08) et un reverse proxy en DMZ (P03, T01, T02). Ouverture externe jugée sous contrôle. La note 3 serait défendable si l'on considère que l'accès public au portail échappe au contrôle de l'organisme. La somme passerait alors à 11 et la cible à 5.	Probable
Q12	Variabilité du SI	**2**	P06, P08	Changements applicatifs mensuels et d'infrastructure trimestriels (P08), deux indisponibilités dues à des changements (P06). Le SI change relativement souvent.	Confirmé

B Maturité effective détaillée (onglet 02)

Table 9. Preuves, exigences non établies et progression

Processus	Preuves	Exigences non établies et réserves	Étape suivante et preuve
Définir la stratégie SSI	P09, P02, P17	Niveau 1 étayé par la note d'orientation 2024 approuvée par la DG, des priorités annuelles et un référent (P09). Niveau 2 indéterminé car aucune mesure qualitative n'est documentée et le compte rendu semestriel reste oral, sans trace écrite fournie. Niveau 3 non atteint, faute de processus commun documenté (P09). Revue annuelle de la PSSI sans PV depuis deux ans (P17).	Tableau de bord qualitatif semestriel et comptes rendus écrits validés par la DG, intégrés au lot A01 (pilote RSSI). Preuve : deux PV de revue datés.

Processus	Preuves	Exigences non établies et réserves	Étape suivante et preuve
Gérer les risques SSI	P10, P06	Risques recensés ponctuellement lors de projets récents, avec des mesures décidées (P10). Niveau 2 non atteint : ni calendrier de revue, ni méthode réutilisable, ni registre consolidé approuvé. L'analyse du prestataire de 2025 reste isolée.	Méthode simple, registre consolidé et revue trimestrielle (A01). Preuve : registre approuvé par la DG et PV de revue.
Gérer les règles SSI	P11, P17, T06	Niveau 2 étayé par une PSSI approuvée, des règles écrites, une application planifiée, des contrôles qualitatifs consignés et l'information des managers (P11). Niveau 3 non atteint, les textes ne forment pas un processus commun. Fragilités : revue annuelle sans PV (P17) et aucune cible de délai de correctifs (T06).	PSSI révisée avec délais de correctifs par criticité, diffusée à tout le périmètre (A03). Preuve : PSSI v2 approuvée, PV de revue, taux de sensibilisation.
Superviser la SSI	P12, P06, T08	Outil de journalisation et alertes actifs, interventions à la demande (P12), d'où le niveau 1. Niveau 2 non atteint : aucune campagne de contrôle planifiée, aucun reporting régulier ni procédure commune (P12). AL-1048 fermée automatiquement sans ticket (T08).	Plan de contrôle annuel, procédure de traitement des alertes et reporting mensuel (A02). Preuve : échantillon de tickets d'alerte qualifiés et rapports mensuels.
Concevoir les mesures SSI	P13, T02	Besoins identifiés sur certains projets, fiche type, responsable technique désigné, revues planifiées pour les projets majeurs avec compte rendu écrit remonté au responsable (P13). Le compte rendu écrit des revues est retenu comme mesure qualitative. La compétence est retenue, comme pour les autres processus, sur la base d'un rôle désigné chargé de la sécurité, à confirmer en entretien. Niveau 3 non atteint, la démarche n'est pas globale. La règle provisoire FW-17 (T02) l'illustre sans le prouver.	Fiche de besoins SSI obligatoire pour tout projet ou changement significatif (préparée en régie, A04 différée). Preuve : fiches sur un échantillon de projets.
Réaliser les mesures SSI	P14, T02	Niveau 1 étayé par des déploiements préparés par des techniciens compétents (P14). Comptes rendus d'installation et de validation, suivi régulier et information de la DSI couvrent quatre exigences du niveau 2. Niveau 2 indéterminé car la planification n'est pas démontrée, P14 indiquant seulement que les déploiements sont « souvent préparés ». Règles FW-17 et FW-31 sans justification ni validation (T02).	Plan de déploiement trimestriel des mesures et modèle commun de recette, en régie (pilote DSI). Preuve : plans datés et PV de recette sur trois déploiements.

Processus	Preuves	Exigences non établies et réserves	Étape suivante et preuve
Exploiter les mesures SSI	P15, P17, T03, T04, T06, T09	Sauvegardes planifiées, comptes rendus hebdomadaires, astreinte, procédure de restauration connue et bilan qualitatif mensuel à la DSI (P15). Niveau 3 non atteint. Fragilités : 2 PV de test sur 9 services (T09), MFA sur 6 comptes privilégiés sur 10 (T04), correctifs en retard sans exception (T06), déclarations de la DG non démontrées et de la DSI contredites (P17).	Standardiser restauration, correctifs et revue des comptes (A05, A08, A09). Preuve : PV de restauration avec RTO et RPO mesurés, export MFA, SLA de correctifs.

C Registre des constats techniques (onglet 03)

Table 10. Observations, qualifications et priorités

ID	Pièces	Observation	Qualification et réserve	Priorité justifiée
C01	T03/T04	10 comptes privilégiés recensés, 6 enrôlés MFA (60 %). Sans MFA : svc-backup, admin-old (Domain Admin, dernière activité documentée 2025-02-14), admin-presta (VPN prestataire) et admin-db.	Fait documenté sur le périmètre de l'export (annuaire et administrateurs VPN). Exhaustivité SaaS non garantie, accès conditionnel et exceptions non fournis. Contredit la déclaration de la DSI (P17).	Élevée : privilèges étendus, accès VPN exposé, signaux T07 sur admin-old.
C02	T02/T01	La règle FW-31 autorise tout service du VLAN 40 (postes) vers le VLAN 60 (BACKUP01). Règle héritée sans justification.	Configuration extraite sans journaux de trafic. Usage réel inconnu. Aucune exploitation constatée.	Élevée : les sauvegardes sont le dernier recours de reprise et l'hameçonnage est fréquent (P06).
C03	T05/T06	APP01 (criticité métier critique) sans correctif critique éditeur (CVSS communiqué 9,8, T05). L'hôte affiche 74 jours de retard de correctifs au 12/10/2026, exception non documentée (T06).	Non exposé directement à Internet et non exploité pendant l'audit. Date de publication du correctif critique, CVE, version et historique de déploiement absents. Retard déclaratif.	Élevée : actif critique joignable depuis la DMZ, aucune exception validée. Le score seul ne fixe pas la priorité.
C04	T07/T08	Le 09/10/2026, trois échecs puis un succès VPN pour admin-old depuis 198.51.100.44 (00:13), ajout au groupe Server-Admins (00:18), alerte AL-1048 de sévérité HIGH (00:22) fermée automatiquement après 24 h sans ticket.	Signaux compatibles avec un événement à investiguer, pas une compromission prouvée. Intégrité des journaux, trace MFA et contact du titulaire non fournis. Incohérence avec la dernière activité T03 (2025-02-14).	Très élevée : privilège Domain Admin, compte sans MFA, aucun examen de l'alerte tracé.
C05	T09	9 services dans le périmètre, 2 PV de test (MEDI-PORTAL le 15/09, ticketing le 16/09/2026), 7 sans PV. RPO non fourni. Sauvegarde M365 alléguée chez un tiers.	L'absence de PV ne prouve pas l'absence de test. Le contenu des deux PV n'est pas communiqué, le respect du RTO de 8 h n'est donc pas démontré (P01, T09). Déclaration de la DG non démontrée (P17).	Élevée : engagement contractuel et continuité des soins (P01, P05).

ID	Pièces	Observation	Qualification et réserve	Priorité justifiée
C06	T02/T01	FW-17 autorise RDP (3389/TCP) depuis VPN-ADMIN vers tout le VLAN 20, sans passer par BASTION01. Règle déclarée provisoire.	Durée, utilisateurs et journaux non fournis. Le contournement du bastion est déduit du schéma T01.	Élevée : accès d'administration direct vers les serveurs critiques.
C07	T02/T05/ T06	FW-19 ouvre SMB (445/TCP) de tout le VLAN 40 vers le VLAN 30. Signature SMB non obligatoire sur SRV-FICHIERS (CVSS 6,5). Correctifs en retard de 43 jours.	Constat de scanner non validé manuellement. Périmètre « large » sans liste des partages.	Moyenne à élevée : exposition interne étendue et hameçonnage fréquent.
C08	T02/T05	Depuis le point de mesure DMZ, WEB01 répond sur 80/tcp et 443/tcp, 22/tcp filtré. Le scanner signale TLS 1.0 (CVSS 5,3). La redirection HTTP vers HTTPS est déclarée, non vérifiée.	Scan non authentifié depuis la DMZ, aucune vue depuis Internet. Validation manuelle absente. Un port ouvert ne prouve pas une faille exploitée.	Modérée : exposé à Internet mais impact limité si la redirection est effective.
C09	T06/P11/ T05	La PSSI ne fixe aucun délai de correctifs par criticité. Retards de 12 j (WEB01), 43 j (SRV-FICHIERS) et 74 j (APP01) sans exception validée. AD01 à jour selon l'agent (inventaire du 25/09/2026).	Retards déclaratifs, historiques de déploiement absents. Inventaire AD01 ancien de 17 jours à la date de contrôle.	Élevée : cause commune de C03, C07 et C08.
C10	P06/P12/ T08	Registre de 10 événements non exhaustif et non revu en comité (P06). Alertes parfois conservées dans les tickets (P12), AL-1048 sans ticket (T08).	Pièces de gouvernance déclaratives, cohérentes avec T08.	Élevée : conditionne la détection.
C11	T03/T09	svc-backup, compte technique à droits élevés sans MFA, déclaré non interactif par la DSI sans preuve de restriction.	Déclaration non étayée. Lien avec BACKUP01 probable mais non documenté.	Élevée : touche la capacité de reprise.

Table 11. Processus, scénario, recommandation et preuve de clôture

ID	Processus	Scénario de risque	Recommandation et pilote	Preuve de clôture
C01	Exploiter les mesures SSI	Prise de contrôle d'un compte privilégié sans second facteur puis modification non autorisée de l'AD (R01).	DSI (IAM) : désactiver ou justifier admin-old, MFA pour admin-presta et admin-db, restriction de svc-backup (A08).	Export MFA exhaustif à 100 % ou exceptions approuvées, preuve de restriction de svc-backup, revue des groupes à privilèges.
C02	Concevoir / Réaliser les mesures SSI	Un poste compromis par hameçonnage atteint BACKUP01 et chiffre ou supprime les copies, ce qui empêche la reprise (R02).	DSI réseau : restreindre FW-31 aux flux nécessaires après analyse des journaux, en régie sous un mois.	Règle supprimée ou justifiée et approuvée, journaux de trafic sur 30 jours, test de segmentation.
C03	Exploiter les mesures SSI	Rebond depuis WEB01 (flux WEB01 vers APP01) ou via RDP (FW-17) puis exploitation d'APP01, altération ou fuite de données patients (R03).	Responsable infrastructures : correctif sous 15 jours ou exception signée avec mesures compensatoires, traité en tête du lot A09.	Scan authentifié après correctif, ticket de changement, version installée.

ID	Processus	Scénario de risque	Recommandation et pilote	Preuve de clôture
C04	Superviser la SSI	Usage frauduleux non détecté d'un compte à privilèges et persistance de droits (R01).	RSSI : ouvrir un incident, mesures conservatoires (désactivation d'admin-old, revue de Server-Admins, préservation des journaux), investigation, fin de la fermeture automatique des alertes HIGH (A02).	Ticket d'incident qualifié, rapport d'investigation, membres de Server-Admins avant et après, paramétrage SIEM modifié.
C05	Exploiter les mesures SSI	Restauration impossible ou trop lente après rançongiciel, dépassement du RTO contractuel (R02).	Responsable infrastructures : plan de tests trimestriel couvrant les 9 services (A05).	PV de restauration datés avec durée mesurée et RPO constaté pour chaque service.
C06	Réaliser les mesures SSI	Un compte VPN sans MFA (admin-presta) atteint APP01 ou DB01 en RDP sans traçabilité du bastion (R01, R03).	DSI : retirer FW-17 ou lui fixer une date d'expiration, imposer le passage par le bastion.	Règle supprimée, connexions RDP tracées sur BASTION01.
C07	Concevoir les mesures SSI	Relais d'authentification ou propagation latérale depuis un poste compromis, divulgation de données (R04).	Responsable infrastructures : signature SMB obligatoire, restriction de FW-19 aux groupes métiers (A09).	Stratégie de groupe appliquée, scan de contrôle, matrice des partages.
C08	Exploiter les mesures SSI	Dégradation du chiffrement des sessions du portail public (R05).	Responsable infrastructures : désactiver TLS 1.0 et 1.1, vérifier la redirection et activer HSTS, scan externe de contrôle (A09).	Rapport de test TLS et preuve de redirection permanente.
C09	Gérer les règles SSI	Fenêtre d'exposition prolongée sur des actifs critiques (R03).	RSSI : SLA par criticité et circuit d'exception (A03, A09).	SLA approuvés, tableau mensuel de conformité, exceptions signées.
C10	Superviser la SSI	Incidents non qualifiés et absence de retour d'expérience (R01).	RSSI : registre unique alimenté par les alertes qualifiées et revue mensuelle (A02).	Registre consolidé, PV de revue, taux d'alertes HIGH qualifiées.
C11	Exploiter les mesures SSI	Détournement du compte de sauvegarde pour supprimer les copies (R02).	DSI (IAM) : interdire l'ouverture de session interactive, secret en coffre, rotation (A08).	Stratégie de refus d'ouverture de session appliquée, journal sans session interactive.

Table 12. Matrice de corrélation complète (T5)

Constat	Preuve	Risque	Processus	Niveau	Action	Pilote	Vérification
C04 AL-1048 fermée sans ticket	T07/ T08	R01	Superviser la SSI	Supervision 1	A02	RSSI	Ticket d'incident qualifié, rapport d'investigation, membres de Server-Admins avant et après, paramétrage SIEM modifié.

Constat	Preuve	Risque	Processus	Niveau	Action	Pilote	Vérification
C01 MFA sur 6 comptes privilégiés sur 10	T03/ T04	R01	Exploiter les mesures SSI	Exploitation 2, fragile	A08	DSI (IAM)	Export MFA exhaustif à 100 % ou exceptions approuvées, preuve de restriction de svc-backup, revue des groupes à privilèges.
C05 PV de restauration pour 2 services sur 9	T09	R02	Exploiter les mesures SSI	Exploitation 2, fragile	A05	Resp. infra-structures	PV de restauration datés avec durée mesurée et RPO constaté pour chaque service.
C03 Correctif critique manquant sur APP01	T05/ T06	R03	Exploiter les mesures SSI	Exploitation 2, fragile	A09	Resp. infra-structures	Scan authentifié après correctif, ticket de changement, version installée.
C02 FW-31 Any des postes vers les sauvegardes	T02/ T01	R02	Concevoir / Réaliser les mesures SSI	Conception 2, Réalisation 1	Régie (A10 différée)	DSI réseau	Règle supprimée ou justifiée et approuvée, journaux de trafic sur 30 jours, test de segmentation.
C09 Aucun délai de correctifs par criticité	T06/ P11/ T05	R03	Gérer les règles SSI	Règles 2	A03, A09	RSSI	SLA approuvés, tableau mensuel de conformité, exceptions signées.

D Registre des risques (onglet 04)

Table 13. Événements redoutés, faiblesses et décisions

ID	Événement redouté	Actif	Vulnérabilité ou faiblesse	I	V	I×V	Décision
R01	Prise de contrôle d'un compte à privilèges menant à une modification non autorisée de l'infrastructure (AD, serveurs)	AD01, BASTION01 et VPN, groupe Server-Admins	4 comptes privilégiés sur 10 non enrôlés MFA dont admin-old (dernière activité documentée en 2025, T03) et admin-presta, RDP direct FW-17, AL-1048 fermée sans examen tracé	4	3	**12**	Réduire (A08, A02) et mesures conservatoires immédiates. Décision DG sur proposition du RSSI.
R02	Indisponibilité de MEDI-PORTAL au-delà du RTO de 8 h faute de restauration fiable (rançongiciel ou panne)	MEDI-PORTAL, base de données MEDI, BACKUP01	2 tests documentés sur 9 services, RPO inconnu, FW-31 Any des postes vers les sauvegardes, svc-backup non restreint	4	3	**12**	Réduire (A05, A08) et restriction de FW-31 en régie. Décision DG.

ID	Événement redouté	Actif	Vulnérabilité ou faiblesse	I	V	I×V	Décision
R03	Altération ou divulgation de données patients via l'application métier non corrigée	APP01, DB01	Correctif critique manquant (T05), hôte en retard de 74 jours (T06), aucun SLA, flux WEB01 vers APP01, RDP FW-17	4	2	**8**	Réduire (A09). Exception signée et mesures compensatoires si le correctif est reporté.
R04	Divulgation de données internes depuis les partages de fichiers après compromission d'un poste, y compris des données de santé si les partages en contiennent (hypothèse)	SRV-FICHIERS, AD01	SMB ouvert à tout le VLAN 40 (FW-19), signature non obligatoire, retard de correctifs de 43 jours	3	3	**9**	Réduire partiellement (A09, A03). Segmentation complète A10 différée, risque résiduel accepté par la DG pour 12 mois.
R05	Interception ou dégradation des sessions du portail public	WEB01, MEDI-PORTAL	TLS 1.0 signalé, port 80 ouvert, redirection non vérifiée	2	2	**4**	Réduire à faible coût dans A09. À défaut, acceptation temporaire par la DSI.
R06	Indisponibilité ou altération de service causée par un changement mal maîtrisé	MEDI-PORTAL, infrastructure	Conception et réalisation non standardisées (P13, P14), règle provisoire non retirée (FW-17)	3	3	**9**	Accepter temporairement (A04 différée en année 2) avec revue de changement renforcée en régie. Risque résiduel porté par la DO.

Table 14. Menaces, mesures existantes et preuves

ID	Menace ou source	Mesures existantes	Preuves
R01	Attaquant externe à motivation cupide (P07) ou abus d'un accès prestataire	MFA enrôlé sur 6 comptes sur 10, SIEM avec alertes, bastion pour une partie des accès	T03, T04, T07, T08, P17 · C01, C04, C06, C10
R02	Rançongiciel après hameçonnage ou erreur d'exploitation	Sauvegardes planifiées, comptes rendus hebdomadaires, site de secours, deux tests documentés	T09, T02, T03, P01, P15, P17 · C02, C05, C11
R03	Attaquant ayant pris pied en DMZ ou sur le VPN d'administration	Absence d'exposition directe à Internet, cloisonnement DMZ et VLAN 20	T05, T06, T02, P05 · C03, C06, C09
R04	Hameçonnage (5 tentatives en 12 mois, P06)	Blocage préventif de comptes, règles d'habilitation (P11)	T02, T05, T06, P06 · C07
R05	Attaquant réseau opportuniste	Publication limitée à 443 et 80 par FW-01 et FW-08, reverse proxy en DMZ	T02, T05 · C08
R06	Erreur interne lors des changements mensuels et trimestriels	Revues de conception des projets majeurs, comptes rendus d'installation	P06, P08, P13, P14, T02 · C06

E Plan d'action détaillé (onglet 05)

Table 15. Coûts, pilotes, échéances et justifications

ID	Mesure	Coût	Choix	Pilote	Échéance et livrable	Justification
A01	Registre et méthode des risques	18 000 €	**Retenu**	RSSI	T+4 mois : méthode, registre consolidé approuvé par la DG, revue trimestrielle, tableau de bord stratégique semestriel	Gérer les risques au niveau 1 (P10). Base de tous les arbitrages R01 à R06. Porte aussi l'étape stratégie (comptes rendus écrits).
A02	Supervision et reporting	16 000 €	**Retenu**	RSSI et exploitation	T+3 mois : procédure de traitement des alertes, plan de contrôle, reporting mensuel	Superviser au niveau 1 (P12). AL-1048 fermée sans ticket (C04, C10). R01.
A03	PSSI et sensibilisation	14 000 €	**Retenu**	RSSI et RH	T+6 mois : PSSI révisée avec SLA de correctifs, PV de revue, campagne anti-hameçonnage	5 hameçonnages sur 10 événements (P06), revue PSSI sans PV (P17), aucun SLA (C09). R04.
A04	Standardisation conception et réalisation	24 000 €	Différé	DSI	Différée en année 2	Conception et réalisation déjà au niveau 2. Fiche SSI obligatoire préparée en régie. Risque résiduel R06.
A05	Restauration et incidents	22 000 €	**Retenu**	Resp. infrastructures	T+6 mois : PV de restauration pour 9 services sur 9, RTO et RPO mesurés, procédure d'incident	2 tests sur 9 (T09), RTO de 8 h (P01). R02. Même lot que T10 restauration, compté une seule fois.
A06	Outillage quantitatif	35 000 €	Différé	RSSI	Différée en année 2	La mesure quantitative relève du niveau 4, prématurée avec des processus à 1 ou 2. Alternative à A11, non cumulée. Risque résiduel : pilotage sans indicateurs chiffrés.
A07	Conduite du changement	14 000 €	Différé	DG et RH	Différée en année 2	Utile mais moins urgente que R01 et R02. Risque résiduel : adhésion insuffisante aux nouvelles pratiques, suivie par la DG et les managers.
A08	MFA et privilèges	28 000 €	**Retenu**	DSI (IAM)	T+3 mois : 100 % des comptes privilégiés sous MFA ou exception approuvée, revue des privilèges, svc-backup restreint	C01, C04, C11. R01 et R02. Déclaration de la DSI contredite par T04.
A09	Vulnérabilités et correctifs	18 000 €	**Retenu**	Resp. infrastructures	APP01 sous 15 jours, puis T+4 mois : inventaire authentifié, SLA par criticité, TLS 1.0 retiré, signature SMB	C03, C07, C08, C09. R03, R04 et R05.

ID	Mesure	Coût	Choix	Pilote	Échéance et livrable	Justification
A10	Segmentation réseau	30 000 €	Différé	DSI réseau	Différée en année 2, FW-31 et FW-17 restreintes en régie sous un mois	Plafond atteint. Risque résiduel R04 et part de R02 acceptés par la DG pour 12 mois.
A11	Détection et workflow SIEM	35 000 €	Différé	RSSI	Différée en année 2	Recoupe A02 pour le workflow d'alerte. Outil à choisir après stabilisation au niveau 2. Alternative à A06. Risque résiduel : détection limitée sur R01, compensée en partie par A02.
	Total retenu	**116 000 €**		Marge 4 000 € sur un plafond de 120 000 €		

F Planning et état des tâches

Table 16. Tâches du Gantt, dépendances fin-début et état au 30 octobre 2026

ID	Tâche	Pilote	Fenêtre	Dépend de	État attesté
E1	Lecture du sujet et des pièces	Tous	20/10 au 21/10	·	À faire (non attesté)
E2	Collecte des preuves P/T	Team	21/10 au 23/10	E1	À relire
E3	G1 Périmètre et limites	Team	24/10 au 26/10	E2	À relire
E4	G2 Autodiagnostic Q01 à Q12	Marc	24/10 au 27/10	E2	À relire
E5	T1 Architecture et flux	Matteo	24/10 au 26/10	E2	À relire
E6	T2 Identités et MFA	Matteo	26/10 au 28/10	E2	À relire
E7	T3 Vulnérabilités	Bernard	24/10 au 26/10	E2	À relire
E8	T4 Journaux et sauvegardes	Bernard	26/10 au 28/10	E2	À relire
E9	Atelier de consolidation	Tous	29/10 au 29/10	E3, E4, E5, E6, E7, E8	À faire (non attesté)
E10	G3 Sept processus	Marc	30/10 au 01/11	E9	À relire
E11	T5 Corrélation	Matteo	30/10 au 01/11	E9	À relire
E12	G4 Risques, budget, feuille de route	Team	02/11 au 03/11	E10, E11	À relire
E13	Remplissage progressif de l'Excel	Bernard	24/10 au 03/11	E2	À relire
E14	Rédaction du rapport	Team	04/11 au 06/11	E12, E13	À relire
E15	Relectures croisées	Tous	07/11 au 07/11	E14	À faire

ID	Tâche	Pilote	Fenêtre	Dépend de	État attesté
E16	Corrections	Marc	08/11 au 08/11	E15	À faire
E17	Compilation et contrôle du PDF	Team	09/11 au 09/11	E16	À faire
E18	Présentation CODIR et répétition	Matteo	04/11 au 09/11	E12	En cours (diapositives prêtes, répétition à faire)

G Sources

SGDN/DCSSI, *Maturité SSI, approche méthodologique*, 2 novembre 2007, consultée sur le site de l'ANSSI (cyber.gouv.fr). Sujet du TD 2, dossier de gouvernance P01 à P17, dossier technique T01 à T10, notice de remplissage et grille Excel fournis. MEDICA-SERVICES, ses pièces et ses montants sont fictifs.